

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

INFORMATION SECURITY POLICY

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PRO109_00	00	30/04/2026	5
Redatto da	Approvato da	Classificazione	Stato
RSGI + IT Manager	AD – Francesco Epifani	Riservato Alta Direzione + ISMS	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
30/04/2026	30/04/2026	30/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo e ambito

La presente procedura attua, sul perimetro Sistema Informativo, gli impegni espressi dalla Politica integrata del SGI di Toscana Diagnostica (TD-SGI-POL001) — in particolare la dimensione "Sicurezza delle Informazioni" — e costituisce, ai fini del Sistema di Gestione della Sicurezza delle Informazioni (ISMS), il documento operativo che declina i requisiti di ISO/IEC 27001:2022 §A.5.1 (Policies for information security) e gli analoghi requisiti di NIS2 (D.Lgs. 138/2024 art. 24), AI Act (Reg. UE 2024/1689), GDPR e settore sanitario.

L'ambito di applicazione è coincidente con il perimetro ISMS dichiarato nello Statement of Applicability TD-SGI-REG016: tutti i sistemi informativi, le informazioni, le applicazioni, le infrastrutture, gli endpoint, i servizi cloud e i fornitori critici ICT che concorrono all'erogazione dei servizi sanitari di Toscana Diagnostica.

La procedura si rivolge a tutto il personale di TD (dipendenti, collaboratori, consulenti, fornitori in servizio), con doveri specifici per i ruoli ICT, l'Alta Direzione, l'RSGI, il DPO, il PdC NIS, il MSSP/SOC esternalizzato.

2. Riferimenti

Riferimento	Ambito
TD-SGI-POL001	Politica integrata del SGI - dimensione Sicurezza delle Informazioni
TD-SGI-REG016 (SoA ISO 27001)	93 controlli Annex A applicabili e attribuiti
TD-SGI-PLN009 (Piano MTOM NIS2)	10 aree MTOM - scadenza 1/10/2026
TD-SGI-PRO070 (Adeguamento NIS2)	Catena risposta incidenti, gestione fornitori
TD-SGI-PRO085 (AI Governance)	Governance sicurezza dei sistemi AI
ISO/IEC 27001:2022 + 27002:2022	Norme di riferimento ISMS
NIST CSF 2.0	Framework metodologico
GDPR Reg. UE 2016/679	Riservatezza dati personali

3. Principi di Information Security

TD adotta i seguenti principi guida nella gestione della sicurezza delle informazioni:

#	Principio	Applicazione operativa in TD
1	Confidentiality - Integrità - Availability (CIA)	Trade-off equilibrato fra le tre proprietà; per dati clinici (Cat. 9 GDPR) prevale Confidentiality + Integrity senza compromessi sulla Availability operativa
2	Defense in depth	Controlli stratificati (perimetro - rete - endpoint - applicazione - dato); compromissione di un layer non causa compromissione totale
3	Least privilege e need-to-know	Accessi minimi necessari; segregazione duties; principio Zero Trust applicato progressivamente (ZTNA in roadmap MTOM area 8)
4	Security by design	Ogni nuovo progetto include valutazione IS in fase di scoping

		(cfr. PRO086 Change Management ICT - PRO018 esistente)
5	Privacy by design (art. 25 GDPR)	Coordinamento con Area 09 Privacy + DPIA per ogni trattamento ad alto rischio
6	Risk-based thinking	Risk assessment ISO 27005 alla base; risorse allocate sui rischi più elevati
7	Continuous improvement	PDCA: monitoraggio, audit, riesame, azioni correttive
8	Accountability	Owner per ciascun controllo definito nel SoA; tracciabilità documentale completa

4. Tassonomia delle informazioni e classificazione

TD classifica tutte le informazioni che tratta in 4 livelli, coerenti con la pratica del settore sanitario e con A.5.12 ISO 27001:

Livello	Descrizione	Esempi	Trattamento
L4 - PUBBLICO	Informazioni esplicitamente destinate al pubblico	Sito web; comunicati; pubblicazioni scientifiche	Nessuna restrizione
L3 - INTERNO	Informazioni di lavoro non confidenziali	Procedure SGI non riservate; comunicazioni interne	Accesso per personale TD; non divulgabile a terzi
L2 - CONFIDENZIALE	Informazioni la cui divulgazione comporterebbe danno aziendale	Dati commerciali, contratti, dati HR non sensibili	Cifratura at-rest; accesso need-to-know; NDA
L1 - RISERVATO	Dati personali sanitari (Cat. 9 GDPR), referti, informazioni strategiche, credenziali, segreti aziendali	Referti, anamnesi, dati genetici, password, chiavi crittografiche	Cifratura at-rest e in-transit; accesso minimo motivato; logging completo; data masking ove possibile; conservazione minima necessaria

5. Domini operativi della sicurezza delle informazioni

La presente procedura articola gli adempimenti di sicurezza in 8 domini operativi, ciascuno collegato ai relativi controlli del SoA REG016 e ai documenti del SGI che ne attuano i requisiti.

5.1 Governance della sicurezza

Responsabilità: AD (accountability ultima); RSGI (governance operativa); IT Manager (esecuzione tecnica); DPO (privacy); PdC NIS (incident response esterna); OdV 231 (cyber-reati). Il Riesame della Direzione (PRO008) è l'organo di indirizzo strategico ISMS, con cadenza almeno semestrale per quanto riguarda NIS2 e ISMS.

Riferimenti SoA: A.5.1, A.5.2, A.5.4, A.5.31, A.5.35, A.5.36, A.5.37.

5.2 Risk management

Il risk management ISMS segue ISO/IEC 27005:2022. Risk register MOD039 mantiene la tracciatura quantitativa dei rischi sui sistemi informativi, con valutazione di probabilità e impatto, controlli mitiganti, rischio residuo, owner. Il riesame del risk register è almeno annuale e in occasione di ogni cambiamento materiale.

Riferimenti SoA: A.5.7 (threat intelligence), A.5.31 (legal compliance), A.8.8 (vulnerability management - cfr. PRO094).

5.3 Identità e accessi

Gestione identità su Active Directory + IAM applicativo. Joiner/Mover/Leaver gestito da P&C con ticket IT (target: automation entro 31/08/2026). RBAC documentato; segregazione duties. PAM (Privileged Access Management) entro 1/10/2026. MFA universale entro 30/09/2026.

Password policy: minimo 14 caratteri; rotazione su evento (compromissione, leak); blacklist password compromesse (HaveIBeenPwned); MFA su tutti gli accessi privilegiati e sui servizi esposti.

Riferimenti SoA: A.5.15 - A.5.18, A.8.2, A.8.5, A.8.18.

5.4 Protezione delle informazioni

Cifratura at-rest sui DB clinici (LIS, RIS, PACS); cifratura endpoint (target 100% al 1/10/2026); cifratura in-transit TLS 1.2/1.3 minimum su tutti i servizi web; backup off-site cifrato. Key management centralizzato (KMS o HSM) entro 1/10/2026 con rotazione automatica delle chiavi sensibili.

Data Loss Prevention (DLP) in roadmap Q4 2026. Data masking obbligatorio per dati clinici reali utilizzati in test/training. Retention secondo TD-SGI-PRO058.

Riferimenti SoA: A.5.10, A.5.12-A.5.14, A.5.33, A.5.34, A.7.10, A.8.10-A.8.14, A.8.24.

5.5 Sicurezza fisica e ambientale

Perimetri di sicurezza fisica con accesso controllato a badge; videosorveglianza; aree riservate (server room, archivio referti, laboratorio) con accesso limitato. Datacenter primario in colocation con perimetro fornitore (ISO 27001 + ISO 22301 minimum requirements).

Riferimenti SoA: A.7.1-A.7.14.

5.6 Operazioni e infrastruttura

Hardening baseline endpoint (CIS Benchmark Tier 1) entro 30/09/2026. Patch management mensile per sistemi critici. Vulnerability assessment ricorrente (cfr. PRO094). Logging centralizzato via SIEM gestito da MSSP. Backup policy: giornaliero su LIS/RIS/PACS, settimanale su altri sistemi, retention 90gg minimum, test di ripristino almeno 2/anno.

Riferimenti SoA: A.8.1, A.8.6-A.8.9, A.8.13-A.8.20.

5.7 Sviluppo applicativo sicuro

Per la limitata superficie di sviluppo interno (script automazione + integrazioni AI), code review interno; SAST in roadmap. Per i fornitori (LIS/RIS/PACS): clausole di Secure SDLC nei contratti; VAPT pre-deployment per integrazioni con accesso a dati clinici. Separazione ambienti dev/test/prod.

Riferimenti SoA: A.5.8, A.8.4, A.8.25-A.8.33.

5.8 Continuità operativa e resilienza

BCP (TD-SGI-PLN013) e DRP (TD-SGI-PLN014) emessi contestualmente alla presente procedura. Test di ripristino documentati nel TD-SGI-MOD221. RTO ≤ 4h per LIS, ≤ 8h per altri servizi clinici, ≤ 24h per servizi amministrativi.

Riferimenti SoA: A.5.29, A.5.30, A.8.13, A.8.14.

6. Gestione degli incidenti di sicurezza

Tutti gli incidenti di sicurezza delle informazioni seguono la catena di risposta a 5 fasi documentata in TD-SGI-PRO070 §6 (Adeguamento NIS2). Il PdC NIS (AD) è il punto di contatto unico verso ACN, CSIRT Italia e — coordinandosi con DPO — Garante Privacy.

Documenti operativi: TD-SGI-MOD181 (Registro Incidenti); TD-SGI-MOD184 (Checklist Notifiche); TD-SGI-IDL026 (Trasmissione Portale ACN); TD-SGI-MOD183 (Verbale Tabletop annuale).

Riferimenti SoA: A.5.5, A.5.24-A.5.28, A.6.8.

7. Sensibilizzazione e formazione

Piano formativo IS coordinato dal RSGI in collaborazione con P&C. Cadenza minima: 8h/anno per tutto il personale, 16h/anno per ruoli ICT/Alta Direzione, AI literacy art. 4 AI Act per personale che opera con sistemi AI. Phishing simulation 4/anno.

Riferimenti: PLN007 Piano formativo TD; SoA A.6.3.

8. Indicatori di processo e monitoraggio

KPI	Formula	Target	Frequenza
% controlli SoA Implementati	Controlli I / 93	≥ 80% al 1/10/2026	Mensile
% personale formato sull'IS	Formati / Totale	≥ 95%	Trimestrale
MTTD (mean time to detect)	$\Sigma (T \text{ detection} - T \text{ onset}) / N$	≤ 24h	Mensile
MTTC (mean time to contain)	$\Sigma (T \text{ containment} - T0) / N$	≤ 4h per significativi	Mensile
% endpoint con baseline hardening	Hardenati / Totale	100% al 30/09/2026	Mensile
% MFA universale	Servizi con MFA / Servizi tot	100% al 30/09/2026	Mensile
Phishing simulation success rate	Click / Test inviati	≤ 5% (industry benchmark sanitario)	Trimestrale
VAPT - findings High/Critical chiusi	Chiusi / Totali	≥ 90% entro 90gg dal report	Per evento

9. Storico delle revisioni

Rev.	Data	Descrizione	Redatto	Approvato
00	30/04/2026	Prima emissione della procedura operativa.	RSGI + IT Manager	AD